

UNCLASSIFIED // FOR OFFICIAL USE ONLY

# AI IMPACT ASSESSMENT

## Federal Compliance Intelligence System (FCIS)

Production-Grade Governed RAG System — Federal Compliance Intelligence

|                         |                                                                                                                                                     |
|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Document Type           | AI Impact Assessment (AIIA)                                                                                                                         |
| System Name             | Federal Compliance Intelligence System (FCIS)                                                                                                       |
| System Version          | 1.0                                                                                                                                                 |
| Sponsoring Organization | U.S. Department of XXXX, Office of XXXX, Compliance Division                                                                                        |
| System Owner            | Raghunath Devayajanam                                                                                                                               |
| Role                    | AI Architect                                                                                                                                        |
| Classification          | UNCLASSIFIED                                                                                                                                        |
| Date                    | April 2026                                                                                                                                          |
| Package Version         | 1.0                                                                                                                                                 |
| Framework References    | NIST AI RMF 1.0   EO 13960   OMB M-21-06   NIST SP 800-53 Rev. 5                                                                                    |
| Repository              | <a href="https://github.com/ai-systems-architect/governed-compliance-engine">https://github.com/ai-systems-architect/governed-compliance-engine</a> |

NOTICE: This is a non-operational sample AI Impact Assessment created for portfolio demonstration. It is modeled on federal AI governance documentation patterns (NIST AI RMF 1.0, EO 13960, OMB M-21-06) but is not an official government authorization artifact. The sponsoring agency named above is fictional. All technical content reflects a real, functioning RAG pipeline built on public NIST and FedRAMP compliance documents.

## Document Control

---

### Revision History

| Version | Date       | Author                | Description                                                          |
|---------|------------|-----------------------|----------------------------------------------------------------------|
| 1.0     | April 2026 | Raghunath Devayajanam | Initial AIIA — governed-compliance-engine v1.0 portfolio deployment. |

### Document Purpose

This AI Impact Assessment (AIIA) evaluates the specific risks, limitations, and governance requirements associated with the GenAI components of governed-compliance-engine. It supplements a standard System Security Plan (SSP) and Risk Assessment Report (RAR) with AI-specific analysis required under Executive Order 13960 and OMB M-21-06.

The risks addressed in this document are specific to the RAG architecture and are not covered by a standard IRSS-type ATO: hallucination, retrieval integrity failure, source authority and currency, overclaiming, prompt injection, and PII leakage into external observability traces. Each risk is novel to systems combining vector retrieval with large language model generation in a federal compliance context.

### Applicable Laws, Regulations, and Standards

| Reference                          | Title                                                                              |
|------------------------------------|------------------------------------------------------------------------------------|
| EO 13960                           | Promoting the Use of Trustworthy Artificial Intelligence in the Federal Government |
| OMB M-21-06                        | Guidance for Regulation of Artificial Intelligence Applications                    |
| NIST AI RMF 1.0                    | Artificial Intelligence Risk Management Framework                                  |
| NIST AI 600-1                      | Artificial Intelligence Risk Management Framework for Generative AI                |
| NIST SP 800-53 Rev. 5              | Security and Privacy Controls for Information Systems and Organizations            |
| FISMA (44 U.S.C. § 3551)           | Federal Information Security Modernization Act                                     |
| E-Government Act of 2002, Sec. 208 | Privacy Impact Assessment Requirements                                             |

## Section 1 — System Characterization

Reference: NIST AI RMF 1.0 MAP Function | NIST SP 800-53 Rev. 5

### 1.1 System Purpose and Capability Boundary

governed-compliance-engine is a production-grade Retrieval-Augmented Generation pipeline over four authoritative federal compliance documents. The system answers compliance questions by retrieving source content, reranking for precision, generating grounded responses via Claude Sonnet 4.5 through Amazon Bedrock, and enforcing guardrails against overclaiming.

| Attribute         | Assessment                                                                                                                                                                                                                                    |
|-------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| System type       | Retrieval-Augmented Generation (RAG) — compliance reference assistant                                                                                                                                                                         |
| Decision type     | Reference and synthesis only. Human review required before any compliance determination.                                                                                                                                                      |
| Automation level  | The system retrieves and synthesizes framework requirements. It does not assess whether a specific system satisfies those requirements. That boundary is enforced in the system prompt and validated by Bedrock Guardrails on every response. |
| Consequential use | Low. System output is a compliance reference — not the basis for an authorization decision.                                                                                                                                                   |
| Domain            | Federal AI and security compliance — NIST, FISMA, FedRAMP                                                                                                                                                                                     |
| Deployment scope  | Portfolio demonstration — Streamlit Community Cloud (GCP), public endpoint, public NIST corpus                                                                                                                                                |

### 1.2 AI Models and Providers

| Model                                                     | Provider       | Role in Pipeline        | Data Transmitted                                                   |
|-----------------------------------------------------------|----------------|-------------------------|--------------------------------------------------------------------|
| Claude Sonnet 4.5                                         | Amazon Bedrock | Response generation     | Top-5 reranked chunks + system prompt. Stays within AWS boundary.  |
| text-embedding-3-large (1536 dims, Matryoshka truncation) | OpenAI         | Dense vector embedding  | Query text at inference time. Chunk text at ingestion. Leaves AWS. |
| rerank-english-v3.0                                       | Cohere         | Cross-encoder reranking | Top-10 retrieved chunks per query. Leaves AWS.                     |

### 1.3 Corpus

| Document                  | Source  | Chunks | Coverage                         |
|---------------------------|---------|--------|----------------------------------|
| NIST SP 800-53 Rev 5      | NIST    | 1,112  | Security and privacy controls    |
| NIST AI RMF 1.0           | NIST    | 50     | AI risk governance framework     |
| NIST AI 600-1             | NIST    | 92     | GenAI-specific risk              |
| FedRAMP Moderate Baseline | FedRAMP | 442    | Cloud authorization requirements |
| Total                     |         | 1,696  | Design through ATO lifecycle     |

## 1.4 Users and Deployment Context

| Attribute          | Assessment                                                                                                     |
|--------------------|----------------------------------------------------------------------------------------------------------------|
| Intended users     | Federal compliance engineers, system owners, ISSOs, AI/ML architects                                           |
| Use context        | Reference lookup during system design, ATO preparation, and control gap analysis                               |
| Deployment         | Streamlit Community Cloud (GCP) — public endpoint, portfolio demonstration                                     |
| Production path    | Private VPC, ECS Fargate, self-hosted Langfuse, Bedrock-native embeddings — documented in docs/architecture.md |
| Impact level       | Not determined by this system — system retrieves framework requirements only                                   |
| Decision authority | Human reviewer — system provides no autonomous compliance determinations                                       |

## Section 2 — RAG-Specific Risk Surface

Reference: NIST AI RMF 1.0 MAP Function | NIST AI 600-1 | EO 13960

The risks below are specific to the GenAI and RAG architecture of this system and are not addressed by a standard IRSS-type ATO. Each risk represents a failure mode unique to systems combining vector retrieval with large language model generation in a federal compliance context. Severity ratings follow NIST SP 800-30 Rev. 1 Likelihood × Impact methodology.

| Risk                                 | Failure Mode and Federal Consequence                                                                                                                                                                                                                                  | Severity |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| Hallucination / faithfulness failure | LLM generates control requirements not present in retrieved chunks or corpus. A federal engineer acts on fabricated NIST citations, producing an inaccurate or non-compliant system design.                                                                           | Critical |
| Retrieval integrity failure          | Incorrect chunks surface for a query. The system produces a factually wrong but confidently stated answer grounded in the wrong source material. Distinguished from hallucination — the answer is traceable to retrieved content but the wrong content was retrieved. | High     |
| Overclaiming / scope creep           | System asserts or implies a compliance determination — e.g., 'your system satisfies AC-6' — rather than describing what AC-6 requires. Highest-severity risk in a federal compliance context where an incorrect determination could affect an authorization decision. | Critical |
| Prompt injection                     | Adversarial query text hijacks pipeline behavior, bypasses guardrails, or causes the system to output harmful or misleading compliance guidance.                                                                                                                      | High     |
| Source authority and currency        | NIST or FedRAMP publishes a revision that supersedes the ingested corpus version. System continues to answer from stale                                                                                                                                               | Medium   |

|                                  |                                                                                                                                                                       |        |
|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
|                                  | control text without surfacing the version limitation.                                                                                                                |        |
| PII leakage into external traces | Query text containing PII is transmitted to Langfuse Cloud, OpenAI, or Cohere before scrubbing, persisting in external observability stores outside the AWS boundary. | Medium |

*Severity definitions: Critical — system outputs could directly cause compliance harm or authorization failure. High — significant risk with multiple mitigating controls required. Medium — acceptable with documented residual risk and monitoring.*

## Section 3 — Control Evidence

Reference: NIST AI RMF 1.0 MEASURE and MANAGE Functions

Each risk identified in Section 2 is addressed by one or more implemented architectural controls. Evidence is cited to specific code modules, decision log entries (DL-series), and evaluation metrics. All decision log entries are maintained in docs/decision\_log.md.

### 3.1 Hallucination / Faithfulness

| Control                          | Evidence                                                                                                                                                                                                                        |
|----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RAGAs faithfulness evaluation    | Faithfulness 0.90 (semantic) / 0.89 (hybrid) against 20-question architect-level golden dataset. Evaluated in evaluation/ragas_eval.py. Primary quality signal for this use case — stable across both retriever configurations. |
| Bedrock Guardrails — output gate | guardrailConfig applied on every Bedrock converse API call. Catches overclaiming and fabricated assertions post-generation. guardrail_action field returned with every response. Implemented in generation/generate.py.         |
| Citation-enforced system prompt  | System prompt instructs Claude to ground every assertion in retrieved chunk content, cite source document and page, and note applicability limitations. No assertion may go beyond what the retrieved context supports.         |
| Pydantic response validation     | GenerateResponse model validates answer, model, stop_reason, and guardrail_action fields before result returns to pipeline. Malformed or truncated responses are rejected. Implemented in generation/generate.py.               |

### 3.2 Retrieval Integrity

| Control                        | Evidence                                                                                                                                                                                                                                                   |
|--------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RAGAs context precision        | Context Precision 0.94 (semantic) / 0.95 (hybrid) — top-ranked chunks are directly relevant to the question before generation runs. Evaluated in evaluation/ragas_eval.py. Confirms Cohere reranking is demoting topically adjacent but irrelevant chunks. |
| Cohere cross-encoder reranking | rerank-english-v3.0 reads query and chunk together — joint inference via attention mechanism — producing a trained relevance probability rather than geometric distance. Top-10 candidates reduced to top-5.                                               |

|                              |                                                                                                                                                                                                                                                                                                                                   |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                              | Implemented in retrieval/rerank.py.                                                                                                                                                                                                                                                                                               |
| Post-RRF quality gate        | MIN_RRF_SCORE=0.0150 drops candidates below threshold before Cohere runs. RRF produces a ranked list regardless of absolute match quality — gate prevents weak candidates from consuming rerank quota. Safety floor of 3 candidates guaranteed. Threshold derived from empirical score distribution. DL-024, retrieval/hybrid.py. |
| BM25 control ID preservation | Control identifiers (AC-6, IR-4) regex-extracted from query before 5-term stop-word limit applies. Always reach the sparse index as high-value anchor terms regardless of query length. DL-019, retrieval/hybrid.py.                                                                                                              |
| Metadata-aware pre-filter    | Rule-based classifier infers control_family and impact_level metadata filters from enriched query text, reducing candidate set before HNSW search. AC-family query reduces corpus from 1,696 to 424 chunks (75% reduction). DL-023, pipeline.py.                                                                                  |

### 3.3 Overclaiming / Scope Creep

| Control                                | Evidence                                                                                                                                                                                                                                                                                                                                                                                                           |
|----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bedrock Guardrails — dual architecture | Input gate (apply_guardrail) fires before retrieval runs — blocks at one Bedrock call cost. Output gate (guardrailConfig) fires post-generation — catches compliance determination assertions. Both gates required: input gate prevents full pipeline cost on blocked queries; output gate catches generation overclaiming. DL-022.                                                                                |
| System prompt compliance boundary      | Explicit instruction: system describes what frameworks require; it does not assess whether a specific system complies. That boundary is stated in the system prompt and tested on every evaluation question.                                                                                                                                                                                                       |
| Negative test corpus grounding         | Three out-of-scope queries (quantum computing key rotation schedules, cryptocurrency transaction validation under FedRAMP, blockchain smart contract auditing) refused via corpus grounding, not guardrails. Rerank scores: 0.071, 0.000436, 0.002726. guardrail_action=none on all three — confirms refusal is retrieval-precision-driven, not guardrail-driven. Documented in Worked Examples section of README. |

### 3.4 Prompt Injection



| Control                         | Evidence                                                                                                                                                                                                                                                                |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Bedrock Guardrails — input gate | apply_guardrail API call before retrieval fires. Blocks injection, jailbreak patterns, and off-topic queries at one Bedrock call cost rather than full pipeline cost. DL-022, generation/generate.py.                                                                   |
| Query enrichment bypass logic   | Enrichment (pronoun resolution via Bedrock Claude) is bypassed on first turn, long queries (8+ words), and queries with no ambiguous pronouns. Reduces attack surface by limiting enrichment invocation to triggered cases only. DL-025, retrieval/query_enrichment.py. |

### 3.5 Source Authority and Currency

| Control                   | Evidence                                                                                                                                                                |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Corpus version documented | NIST SP 800-53 Rev 5, AI RMF 1.0, AI 600-1, FedRAMP Moderate Baseline — versions locked at ingestion. Corpus versions stated in README and PORTFOLIO.md.                |
| Idempotent re-ingestion   | ingestion/embed.py upsert pattern supports full corpus replacement on revision. No schema migration required — re-run ingestion pipeline with updated source documents. |
| Documented gap            | No automated NIST revision detection or re-ingestion trigger. See Section 4 Residual Risk — GAP-001.                                                                    |

### 3.6 PII Leakage into External Traces

| Control                              | Evidence                                                                                                                                                                                                                                                                            |
|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Presidio scrub — query input         | en_core_web_lg NER model replaces PERSON, EMAIL_ADDRESS, US_SSN, IP_ADDRESS and other entity types with bracketed placeholders before any external API call. Query is scrubbed before OpenAI embedding, Cohere reranking, and Langfuse trace emission. utils/pii_filter.py, DL-017. |
| Presidio scrub — generated output    | Second Presidio pass runs on Claude-generated answer before returning to caller. Catches query PII echoed in response. utils/pii_filter.py.                                                                                                                                         |
| Domain allowlist (_DOMAIN_ALLOWLIST) | FedRAMP, NIST, AWS, ISSO, ATO, RMF and 14 other federal program terms excluded from PII scrubbing. en_core_web_lg NER misclassifies these as PERSON entities — allowlist prevents false-positive scrubbing. Discovered on MAIN-3 cross-corpus query. DL-017,                        |

|                                              |                                                                                                                                                                                                |
|----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                              | utils/pii_filter.py.                                                                                                                                                                           |
| Control ID regex protection (_CONTROL_ID_RE) | NIST control identifiers (AC-2, IR-4, SC-28) excluded from PII scrubbing via dedicated regex pattern. Prevents control IDs from being anonymized in queries or responses. utils/pii_filter.py. |

## Section 4 — Residual Risk and Documented Gaps

Reference: NIST AI RMF 1.0 MANAGE Function | NIST SP 800-30 Rev. 1

Residual risks are accepted limitations that do not have current mitigations or where the mitigation is intentional and the gap is explicitly documented. Severity ratings follow NIST SP 800-30 Rev. 1 definitions.

| ID      | Gap                                              | Description                                                                                                                                                                                                                                                                                 | Severity                 | Status   | Path Forward                                                                                                                                                                                |
|---------|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GAP-001 | Source currency — no revision detection          | No automated trigger when NIST or FedRAMP publishes a document revision. Corpus version locked at ingestion. System answers from locked version without surfacing the version date.                                                                                                         | Medium                   | Open     | Idempotent re-ingestion supported. Production operations item — monitoring and re-trigger outside current scope.                                                                            |
| GAP-002 | Answer Relevancy 0.56 / 0.51 — below 0.70 target | RAGAs Answer Relevancy 0.56 (semantic) / 0.51 (hybrid). Metric penalizes compliance-safe hedging language. System prompt instructs Claude to note applicability limitations and avoid overclaiming. Architect-level multi-part questions also fragment RAGAs synthetic question comparison. | Low — accepted by design | Accepted | Optimizing would require weakening safety behavior or simplifying evaluation questions. Both reduce system integrity. Faithfulness (0.90) and Context Precision (0.94) are primary signals. |
| GAP-003 | Corpus ingestion PII scrub not implemented       | Presidio scrub applied at query input and output only. Corpus ingestion pipeline does not scrub chunks before embedding.                                                                                                                                                                    | Low — deferred           | Deferred | Required when corpus includes controlled or sensitivity-tiered documents. AWS Comprehend recommended production path.                                                                       |

|         |                                    |                                                                                                                                                                                                                                                                                    |                  |                       |                                                                                                                                                                       |
|---------|------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|         |                                    | Current corpus is public NIST documents — no PII risk at present.                                                                                                                                                                                                                  |                  |                       | DL-017.                                                                                                                                                               |
| GAP-004 | Langfuse trace scrubbing at source | PII scrubbed before external calls but trace metadata may include enriched query text. Self-hosted Langfuse inside VPC eliminates external transmission entirely.                                                                                                                  | Low — deferred   | Deferred              | Production path: self-hosted Langfuse inside private VPC. LANGFUSE_HOST config switch documented in architecture.md.                                                  |
| GAP-005 | BM25 + metadata filter collapse    | Combined WHERE tsvector_match AND control_family='A C' SQL condition causes BM25 to return zero rows on the filtered corpus subset. Dense retrieval covers the gap — Cohere ranked FedRAMP AC-6 chunk first (rerank score 0.9891) despite BM25 firing=False. Documented in DL-027. | Low — documented | Documented, not fixed | Production fix: run sparse and dense retrieval legs separately, apply metadata filter to dense leg only, fuse post-filter. Does not affect current evaluation scores. |

## 4.1 Risk Acceptance

The System Owner (Raghunath Devayajanam, D Tech LLC) accepts the residual risk profile documented above for the portfolio demonstration deployment of governed-compliance-engine v1.0. GAP-001 is the highest-priority open item and is a blocking condition before deployment against a live-updated corpus. GAP-003 and GAP-004 are blocking conditions before deployment against a corpus containing controlled or sensitivity-tiered documents. All five gaps are tracked and will be reviewed before any production deployment.

## Section 5 — NIST AI RMF 1.0 Alignment

Reference: NIST AI RMF 1.0 — GOVERN, MAP, MEASURE, MANAGE Functions

governed-compliance-engine was designed with explicit alignment to NIST AI RMF 1.0. The four core functions are addressed through architectural decisions, evaluation artifacts, and operational controls. Full implementation details are maintained in docs/decision\_log.md (DL-001 through DL-029). Subcategory mappings in Section 5.1 are derived from the NIST AI RMF 1.0 Playbook (NIST AI RMF Crosswalk and Playbook companion resource).

| Function | Implementation Evidence                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GOVERN   | System prompt enforces compliance reference boundary — no overclaiming permitted on any response. Bedrock Guardrails enforces boundary at input and output on every pipeline execution. Decision log DL-001 through DL-029 documents all architectural choices with alternatives evaluated and rationale. Provider abstraction layer enables model governance — embedding and generation providers swappable via environment variables without pipeline rewrites.                                                                                                                                                                    |
| MAP      | Corpus scope explicitly bounded to four frameworks covering the federal AI compliance lifecycle — design through ATO. System capability ceiling documented in README and enforced in system prompt: reference assistant, not compliance assessor. PII surfaces identified across all four pipeline stages: query input, corpus ingestion, generated output, and Langfuse traces. Deployment boundary disclosures document all external data flows (Section 7). Corpus version documented at ingestion.                                                                                                                               |
| MEASURE  | RAGAs evaluation against 20-question architect-level golden dataset covering all four corpus sources including cross-corpus synthesis questions. Semantic vs hybrid quantified comparison produces defensible retrieval quality signal. Retrieval diagnostics (Recall@5, MRR, nDCG@5) evaluated across three pipeline configurations: semantic-only, hybrid, and hybrid+rerank. Langfuse Cloud traces every pipeline stage with latency and span-level observability. Trace ID returned with every response for post-hoc audit. Worked examples with citation spot-checks validate output quality manually against source documents. |
| MANAGE   | Dual Bedrock Guardrails block overclaiming at input and output. Provider abstraction enables model swap without pipeline rewrite — Bedrock Guardrails is the                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

|  |                                                                                                                                                                                                                                                                                                                                                                                                               |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | only hard AWS dependency by design. AWS Batch recommended for production ingestion — ephemeral containers, pay-per-runtime, no persistent worker infrastructure. RDS lifecycle scripts (scripts/rds_start.py, rds_stop.py) minimize cost between ingestion runs. Production path to full AWS boundary documented in docs/architecture.md. Five residual gaps tracked in Section 4 with path forward for each. |
|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## 5.1 NIST AI RMF Control Summary

| Control ID  | Control Name                 | Status      | Key Implementation Evidence                                                        |
|-------------|------------------------------|-------------|------------------------------------------------------------------------------------|
| GOVERN 1.1  | Policies and Procedures      | Implemented | Compliance boundary in system prompt. Decision log DL-001 to DL-029.               |
| GOVERN 1.7  | Sensitive Attribute Handling | Implemented | PII scrub at input and output. Domain allowlist prevents false positives.          |
| MAP 1.1     | Use Case Scoping             | Implemented | Corpus bounded to four frameworks. Capability ceiling in README and system prompt. |
| MAP 2.1     | Risk Identification          | Implemented | Six RAG-specific risks identified and documented in Section 2.                     |
| MAP 5.1     | Impact Assessment            | Implemented | This document. Residual risk table in Section 4.                                   |
| MEASURE 2.5 | Retrieval Quality Evaluation | Implemented | RAGAs: Faithfulness 0.90, Context Precision 0.94, Context Recall 0.75.             |
| MEASURE 2.6 | Performance Monitoring       | Implemented | Langfuse Cloud — span-level tracing, latency per stage, trace ID per response.     |
| MEASURE 2.7 | Safety Gate Enforcement      | Implemented | Dual Bedrock Guardrails — input gate + output gate on every pipeline execution.    |
| MEASURE 4.1 | Explainability               | Implemented | Source citations in every                                                          |

|            |                             |             |                                                                                     |
|------------|-----------------------------|-------------|-------------------------------------------------------------------------------------|
|            |                             |             | response. Chunk content verifiable against corpus.                                  |
| MANAGE 1.3 | Deployment Approval         | Implemented | No autonomous action. Human reviewer required for all compliance determinations.    |
| MANAGE 2.2 | Risk Response Documentation | Implemented | Section 4 residual risk table. DL-series decision log.                              |
| MANAGE 2.4 | Ongoing Monitoring          | Implemented | Langfuse trace per query. Retrieval diagnostics re-runnable against golden dataset. |

## Section 6 — Human Oversight and Incident Response

Reference: NIST AI RMF 1.0 GOVERN and MANAGE Functions | EO 13960 Section 5

### 6.1 Human Oversight Model

governed-compliance-engine is explicitly designed to support, not replace, human compliance judgment. The system takes no autonomous action on behalf of users. Every response cites the source chunk — document, section, and page — enabling the reviewer to verify the assertion against the original NIST or FedRAMP source. All compliance determinations remain with the human reviewer.

| Attribute              | Description                                                                                                                                                                                                                                         |
|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Autonomous actions     | None — system retrieves, synthesizes, and cites. No action is taken on behalf of users.                                                                                                                                                             |
| Decision authority     | All compliance determinations remain with the human reviewer. System output is reference material.                                                                                                                                                  |
| Citation verification  | Every response cites source chunk with document name, section, and page reference. Human reviewer can verify against original source.                                                                                                               |
| Trace auditability     | Langfuse trace ID returned with every response. Full retrieve / rerank / generate span timeline available for post-hoc audit. Trace includes enriched query, metadata filters applied, BM25 status, post-RRF candidate count, and guardrail action. |
| Guardrail transparency | guardrail_action field (NONE or INTERVENED) returned with every response and visible in Streamlit UI debug sidebar and Langfuse trace.                                                                                                              |
| Version labeling       | Corpus version is static and documented. Responses do not currently surface the corpus version date — production enhancement identified in GAP-001.                                                                                                 |

### 6.2 Failure Mode Response

| Scenario                          | System Behavior                                                                                                                                                 | Human Action Required                                                                              |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| Hallucinated compliance assertion | Faithfulness gate via Bedrock output guardrail. Citation requirement in system prompt. Rerank scores near zero on out-of-scope queries trigger natural refusal. | Review Langfuse trace. Verify cited chunk content against source document at cited page reference. |



|                                           |                                                                                                                                         |                                                                                                                                      |
|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| Prompt injection attempt                  | Bedrock input guardrail blocks before retrieval fires.<br>guardrail_action=INTERVENED<br>returned to caller.                            | Review Langfuse trace for injection pattern. Update guardrail configuration topic or content filters if new pattern identified.      |
| Stale corpus answer                       | No automated detection. System answers from locked corpus version without surfacing version date. Tracked in GAP-001.                   | Periodic corpus review against NIST publication cycle. Re-ingestion on document revision. Production: add version label to response. |
| PII detected in query                     | Presidio scrub replaces PII with type placeholders before any external API call. Original query not transmitted.                        | Review pii_filter.py logs if false positive or false negative suspected. Update _DOMAIN_ALLOWLIST or _CONTROL_ID_RE pattern.         |
| Overclaiming response generated           | Bedrock output guardrail intercepts post-generation.<br>guardrail_action=INTERVENED.<br>Response not returned to caller.                | Review generated content in Langfuse trace. Tighten system prompt compliance boundary or guardrail denied topics if pattern recurs.  |
| Cross-corpus query retrieves wrong source | Cohere reranking reorders RRF candidates by joint query+chunk relevance. Rerank score near zero confirms no relevant content in corpus. | Verify corpus contains the expected source documents. Review metadata filter classifier for misfired pre-filter.                     |

## Section 7 — Data Lineage and Boundary Disclosure

Reference: NIST AI RMF 1.0 MAP Function | NIST SP 800-53 Rev. 5 SC-8, SC-28

This section documents all data flows in the governed-compliance-engine pipeline, identifies which data leaves the AWS boundary, and describes the production path to achieve a full AWS-boundary deployment. Disclosure of external data flows is required before deployment in any federal environment.

### 7.1 Data Flow Summary

| Data Element                              | Origin                  | Destination                            | Purpose                      | AWS Boundary |
|-------------------------------------------|-------------------------|----------------------------------------|------------------------------|--------------|
| Query text (Presidio-scrubbed)            | User via Streamlit      | OpenAI API                             | Dense vector embedding       | Leaves AWS   |
| Top-10 retrieved chunks                   | RDS pgvector            | Cohere API                             | Cross-encoder reranking      | Leaves AWS   |
| Enriched query + pipeline metadata        | Pipeline orchestrator   | Langfuse Cloud (us.cloud.langfuse.com) | Pipeline trace observability | Leaves AWS   |
| Query text + system prompt + top-5 chunks | Pipeline orchestrator   | Amazon Bedrock (Claude Sonnet 4.5)     | Response generation          | Stays in AWS |
| Corpus embeddings and chunk text          | Ingestion pipeline      | RDS PostgreSQL (AWS us-east-1)         | Vector store                 | Stays in AWS |
| Raw corpus PDFs                           | NIST / FedRAMP (public) | Amazon S3 (AWS us-east-1)              | Corpus object storage        | Stays in AWS |
| Processed chunks JSON                     | ingestion/chunk.py      | Amazon S3 (AWS us-east-1)              | Ingestion artifact storage   | Stays in AWS |

### 7.2 Production Path to Full AWS Boundary

The current portfolio deployment sends query text to OpenAI for embedding, top-10 chunks to Cohere for reranking, and pipeline traces to Langfuse Cloud. Three substitutions eliminate all external data flows. The production path is documented in full in docs/architecture.md.

| Current (Portfolio)                     | Production Replacement                                                                           | Data Flow Impact                                                  |
|-----------------------------------------|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
| OpenAI text-embedding-3-large           | Amazon Titan Embed v2 or Cohere Embed via Bedrock                                                | Query text and chunk text remain within AWS boundary at all times |
| Cohere rerank-english-v3.0 (direct API) | Amazon Bedrock Rerank                                                                            | Retrieved chunks remain within AWS boundary at rerank time        |
| Langfuse Cloud (us.cloud.langfuse.com)  | Self-hosted Langfuse inside private VPC. LANGFUSE_HOST environment variable controls switch — no | Pipeline traces and query metadata remain within AWS boundary     |

|                                                     |                                                        |                                                                               |
|-----------------------------------------------------|--------------------------------------------------------|-------------------------------------------------------------------------------|
|                                                     | application code change required.                      |                                                                               |
| RDS public endpoint (required for Streamlit on GCP) | RDS private subnet behind ALB + ECS Fargate inside VPC | No direct database exposure. Application load balancer in public subnet only. |

### 7.3 Corpus Provenance and Integrity

| Attribute             | Description                                                                                                                                      |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Corpus documents      | NIST SP 800-53 Rev 5, NIST AI RMF 1.0, NIST AI 600-1, FedRAMP Moderate Baseline — all public domain publications                                 |
| Sensitivity           | No PII, CUI, or classified information present in any ingested corpus document                                                                   |
| Integrity controls    | S3 versioning enabled on corpus bucket. Idempotent upsert on re-ingestion — chunk IDs derived from content hash prevent duplicate embedding      |
| Access control        | S3 corpus bucket — private, public access blocked, IAM least-privilege. RDS — SSL enforced (rds.force_ssl=1), access scoped to pipeline IAM role |
| Version documentation | Corpus versions stated in README, PORTFOLIO.md, and this document. No automated version surfacing in responses — see GAP-001.                    |

## Authorization Statement

Based on the risk assessment, control evidence, and residual risk profile documented in this AI Impact Assessment, the System Owner accepts the current risk posture for the portfolio demonstration deployment of governed-compliance-engine v1.0. This acceptance is contingent on the five residual gaps in Section 4 being resolved before any deployment against a live-updated corpus or a corpus containing controlled documents.

|                             |                                                                                                                       |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>Authorizing Official</b> | Raghunath Devayajanam                                                                                                 |
| <b>Title</b>                | AI Architect                                                                                                          |
| <b>Date</b>                 | April 2026                                                                                                            |
| <b>Scope</b>                | Portfolio demonstration deployment only                                                                               |
| <b>Conditions</b>           | GAP-001 through GAP-005 reviewed before production deployment. GAP-001, GAP-003, and GAP-004 are blocking conditions. |

---

Authorizing Official Signature | Date

---

*This AI Impact Assessment is a portfolio artifact prepared by Raghunath Devayajanam, AI Architect. Agency and system details are fictional placeholders. Architecture, evaluation metrics, and control implementations reflect the actual governed-compliance-engine system as of the document date. DL-001 through DL-029 in docs/decision\_log.md provides full architectural rationale for all decisions referenced herein.*